

# Web Application Security Assessment Report

**Target:** http://testphp.vulnweb.com/

**Task Level:** Beginner Cyber Security

This report documents a basic web application security assessment performed on the intentionally vulnerable website **testphp.vulnweb.com**.

The purpose of this assessment is to understand fundamental reconnaissance techniques, directory enumeration, and network traffic analysis in a controlled and legal learning environment.

## Tools Used

- **Nmap** – Network scanning and port discovery
- **Dirb / Gobuster** – Directory brute forcing
- **Wireshark** – Network traffic analysis
- **Web Browser** – Manual interaction with the application

## Task 1: Open Port Identification

### Methodology

A network scan was conducted against the target domain to identify open TCP ports and running services.

### Command Used

```
nmap testphp.vulnweb.com
```



```
jackal@kali: ~  
Session Actions Edit View Help  
(jackal@kali)-[~]  
$ nmap testphp.vulnweb.com  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 04:03 EST  
Nmap scan report for testphp.vulnweb.com (44.228.249.3)  
Host is up (0.059s latency).  
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com  
Not shown: 999 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 18.10 seconds
```

### Observations

- The scan revealed that **port 80 (HTTP)** was open.

- The service running on this port was identified as a web server.
- No additional open ports were detected during the scan.

## Conclusion

The application is accessible over an unencrypted HTTP service, which may expose sensitive data during transmission.

## Task 2: Directory Enumeration

### Methodology

Directory brute forcing was performed to discover hidden or unlinked directories within the web application.

### Command Used

dirb <http://testphp.vulnweb.com/>

```
(jackal@kali)-[~]
$ gobuster dir -u http://testphp.vulnweb.com/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://testphp.vulnweb.com/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/admin (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/admin/]
/cgi-bin/ (Status: 403) [Size: 276]
/cgi-bin (Status: 403) [Size: 276]
/crossdomain.xml (Status: 200) [Size: 224]
/ CVS/Repository (Status: 200) [Size: 8]
/ CVS/Entries (Status: 200) [Size: 1]
/ CVS (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/ CVS/]
/ CVS/Root (Status: 200) [Size: 1]
/ favicon.ico (Status: 200) [Size: 894]
/ images (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/ images/]
/ index.php (Status: 200) [Size: 4958]
/ pictures (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/ pictures/]
/ secured (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/ secured/]
/ vendor (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/ vendor/]
Progress: 4613 / 4613 (100.00%)

Finished
```

## Conclusion

Multiple accessible directories were discovered, some of which expose application functionality and could be potential attack surfaces.

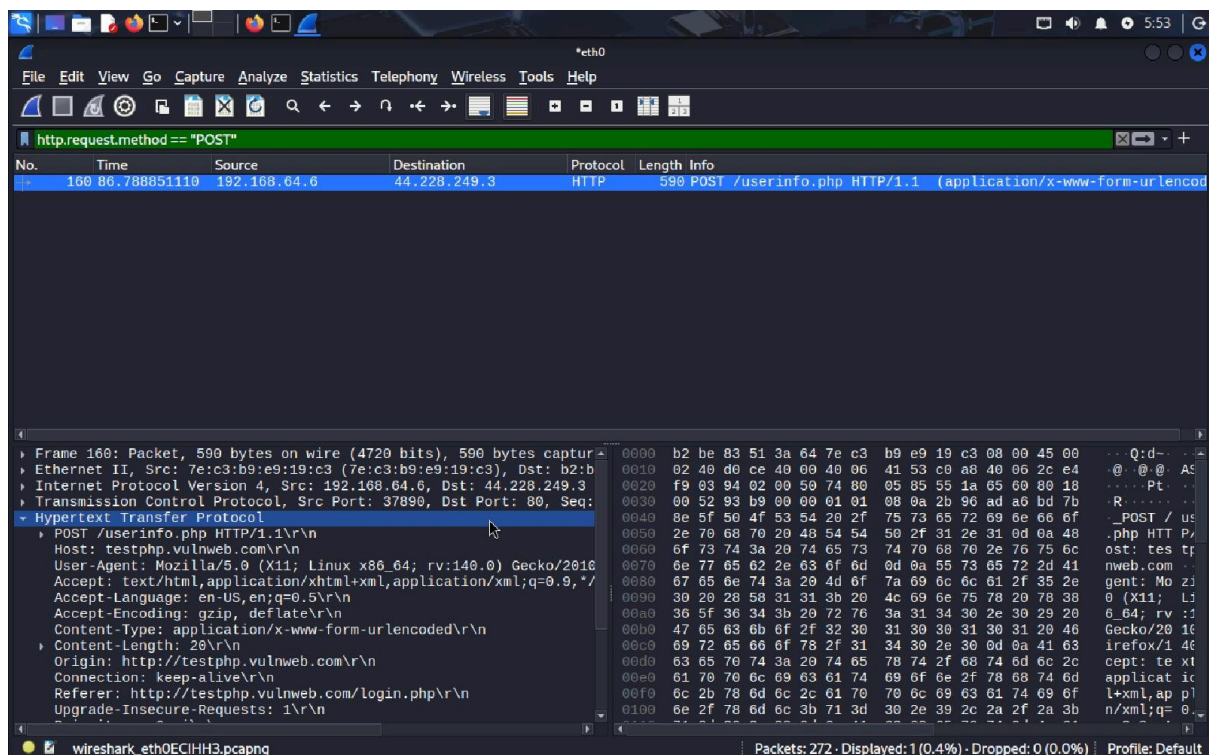
## Task 3: Network Traffic Analysis & Credential Interception

### Methodology

1. Wireshark was started to capture network packets.
2. A login attempt was made on the website using test credentials.
3. Captured traffic was filtered using the HTTP protocol filter.

### Wireshark Filter Used

http



```
Referer: http://testphp.vulnweb.com/login.php\r\n
Upgrade-Insecure-Requests: 1\r\n
Priority: u=0, i\r\n
\r\n
[Response in frame: 165]
[Full request URI: http://testphp.vulnweb.com/userinfo.php]
File Data: 20 bytes
HTML Form URL Encoded: application/x-www-form-urlencoded
  ▶ Form item: "uname" = "test"
  ▶ Form item: "pass" = "test"
```

## Observations

- Login credentials were transmitted in **plain text**.
- Username and password values were visible in the HTTP POST request.
- This occurred due to the absence of HTTPS encryption.

## Conclusion

The use of HTTP instead of HTTPS allows attackers to intercept sensitive credentials via network sniffing, demonstrating a serious security risk.

## Report Conclusion

This assessment demonstrated how basic reconnaissance and traffic analysis techniques can expose critical security flaws in a web application.

The exercise highlights the importance of encrypted communication and secure configuration practices in modern web applications.